

W24D4 - Report M6 Progetto Splunk con tutorialdata.zip

Miriana Fiorito – miry.fiorito@gmail.com

1.1 Introduzione a Splunk: Definizione, Funzionalità e Ambiti di Utilizzo

Splunk è una piattaforma avanzata per la raccolta, l'indicizzazione, la ricerca e l'analisi di dati generati da sistemi informatici, dispositivi di rete, applicazioni e infrastrutture cloud. Nata nel 2003, Splunk si è affermata come uno degli strumenti più potenti per la gestione dei log e l'osservabilità dei dati aziendali, sia on-premise che in ambienti cloud. La sua architettura modulare e scalabile consente di monitorare e analizzare enormi volumi di dati in tempo reale, fornendo insight fondamentali per la sicurezza, il troubleshooting e l'ottimizzazione delle performance IT. La piattaforma si distingue per la capacità di trasformare dati grezzi in informazioni "actionable", ovvero dati pronti per essere utilizzati in processi decisionali e operativi. Splunk non è solo un SIEM (Security Information and Event Management), ma una soluzione di osservabilità che integra funzioni di analisi, correlazione, visualizzazione e automazione, adattandosi a diversi contesti aziendali.

1.2 Funzionalità Principali

Le principali funzionalità di Splunk includono:

- **Raccolta e indicizzazione dei dati:** Splunk può acquisire dati da file di log, stream di rete, API, database e molte altre fonti, supportando formati come CSV, JSON, XML e dati non strutturati.
- **Ricerca e analisi avanzata:** Grazie al linguaggio SPL (Search Processing Language), Splunk permette di eseguire query complesse, estrarre campi, correlare eventi e generare statistiche.
- **Visualizzazione e dashboard:** La piattaforma offre strumenti per la creazione di dashboard interattive, report personalizzati e alert in tempo reale.
- **Automazione e workflow:** Splunk integra funzioni di automazione per la risposta agli incidenti, la gestione degli allarmi e l'esecuzione di playbook di sicurezza.

- **Machine Learning e analisi predittiva:** Attraverso moduli dedicati (MLTK), Splunk consente di applicare algoritmi di machine learning per la rilevazione di anomalie e la previsione di eventi.

1.3 Architettura di Splunk e Componenti Principali

L'architettura di Splunk è progettata per garantire scalabilità, resilienza e flessibilità. I componenti principali sono:

Componente	Funzione Principale
Forwarder	Raccolta e inoltro dei dati dai sistemi sorgente verso gli indexer
Indexer	Parsing, indicizzazione e memorizzazione dei dati, gestione delle query
Search Head	Interfaccia utente per la ricerca, analisi, dashboard e report
Deployment Server	Gestione centralizzata delle configurazioni e distribuzione di app e aggiornamenti
License Master	Gestione delle licenze e monitoraggio del volume di dati indicizzati
Cluster Master	Coordinamento dei cluster di indexer per alta disponibilità e replica dei dati

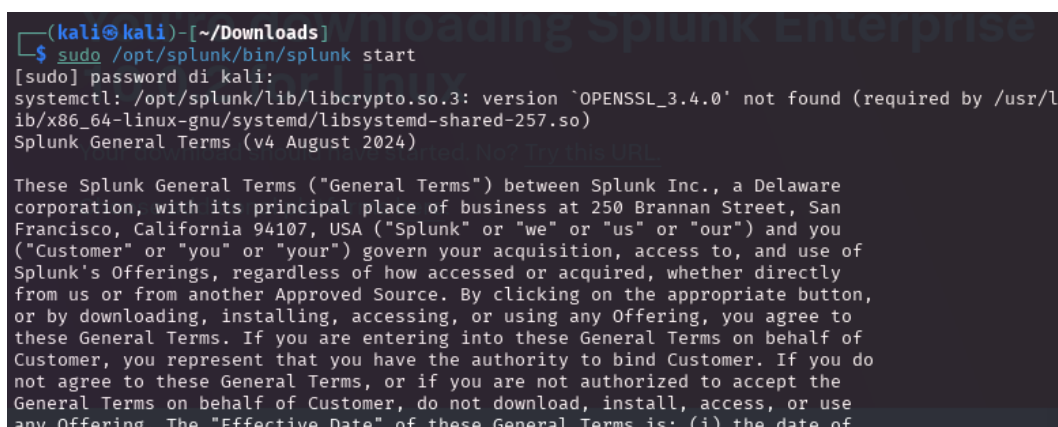
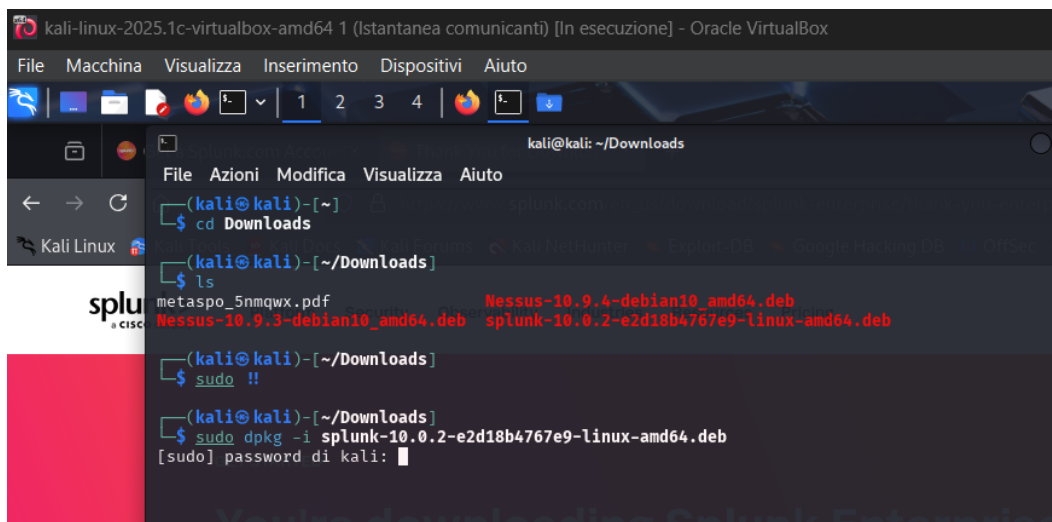
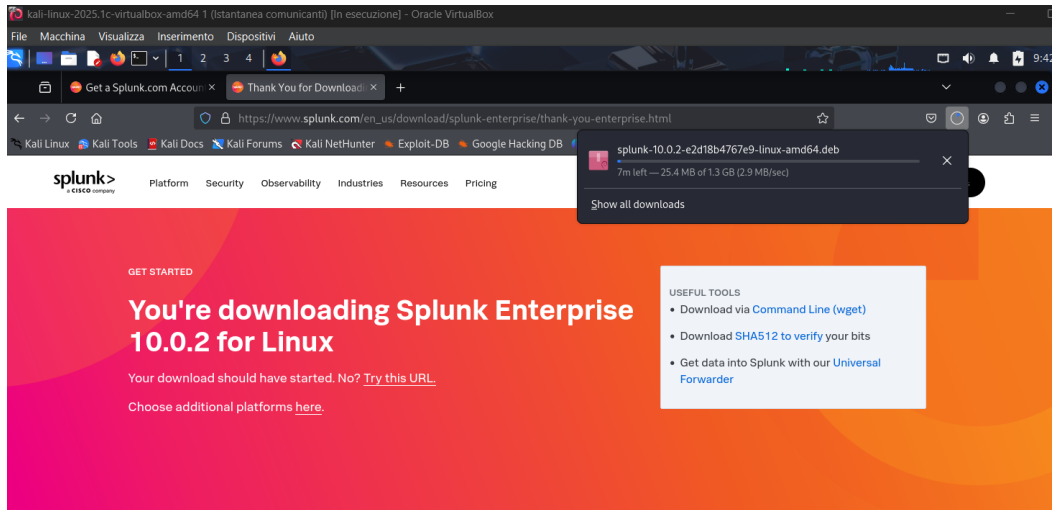
L'architettura può essere implementata in modalità standalone (tutti i componenti su un unico server) o distribuita (componenti separati su più server per scalabilità e resilienza). *Il Forwarder* è un agente leggero installato sui sistemi sorgente, responsabile della raccolta e dell'inoltro dei dati. Esistono due tipi: Universal Forwarder (inoltra dati grezzi) e Heavy Forwarder (esegue parsing e filtraggio locale). *L'Indexer* riceve i dati dai forwarder, li trasforma in eventi, li indicizza e li memorizza su disco. Gestisce la replica dei dati per garantire la disponibilità e la protezione contro la perdita di informazioni. *Il Search Head* offre l'interfaccia grafica per la ricerca, l'analisi e la visualizzazione dei dati. In ambienti distribuiti, può essere configurato in cluster per gestire grandi volumi di query e utenti simultanei. *Il Deployment Server* facilita la gestione centralizzata delle configurazioni, delle app e degli aggiornamenti, mentre il *License Master* monitora la compliance delle licenze. *Il Cluster Master* coordina la replica dei dati tra indexer in cluster, assicurando alta disponibilità e disaster recovery.

2. Installazione di Splunk (Kali Linux)

2.1 Installazione su Linux

Come primo passo ho creato un account sul sito splunk, inserendo tutti i dati per la registrazione. Una volta registrati si scarica la versione Splunk Enterprise selezionando

sistema operativo (in questo caso Linux) creando poi un account gratuito a seguito dell'installazione tramite il terminale della nostra kali.



```

Do you agree with this license? [y/n]: y
You agree to be your first time running this version of Splunk.
Splunk software must create an administrator account during startup. Otherwise, you cannot log in.
Create credentials for the administrator account.
Characters do not appear on the screen when you type in credentials.

Please enter an administrator username: admin
Password must contain at least:
  * 8 total printable ASCII character(s).
Please enter a new password:
Please confirm new password:
ERROR: Password did not meet complexity requirements. Password must contain at least:
  * 8 total printable ASCII character(s).
Please enter a new password:
Please confirm new password:
Copying '/opt/splunk/etc/openldap/ldap.conf.default' to '/opt/splunk/etc/openldap/ldap.conf'.
writing RSA key

writing RSA key

Moving '/opt/splunk/share/splunk/search_mrsparkle/modules.new' to '/opt/splunk/share/splunk/search_mrsparkle/modules'.
systemctl: /opt/splunk/lib/libcrypto.so.3: version `OPENSSL_3.4.0' not found (required by /usr/lib/x86_64-linux-gnu/systemd/libsystemd-shared-257.so)

Splunk> CSI: Logfiles.

Checking prerequisites...
Checking http port [8000]: open
Checking mgmt port [8089]: open
Checking answerer port [127.0.0.1:8065]: open

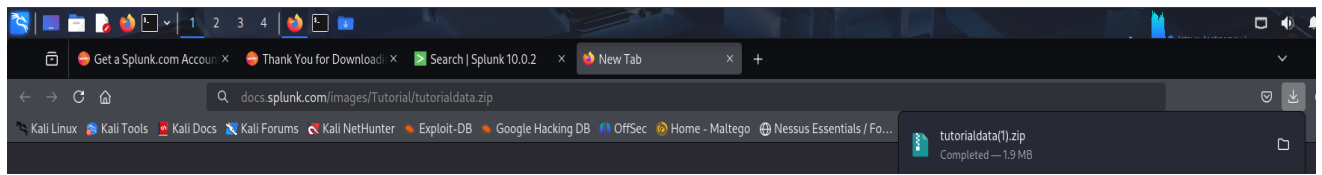
```

[illegible]

3. Procedura di Importazione del File tutorialdata.zip in Splunk

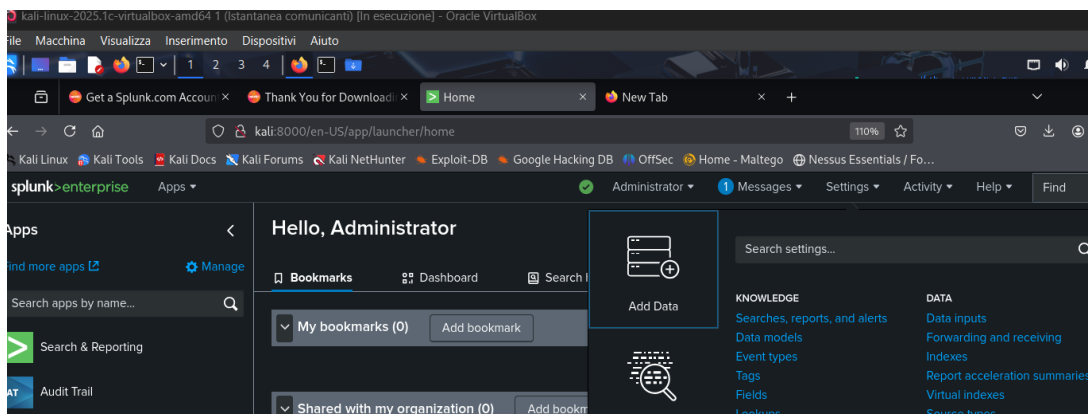
L'importazione del dataset `tutorialdata.zip` è un passaggio fondamentale per eseguire analisi e query SPL.

1. Preparazione del file importandolo sulla nostra kali

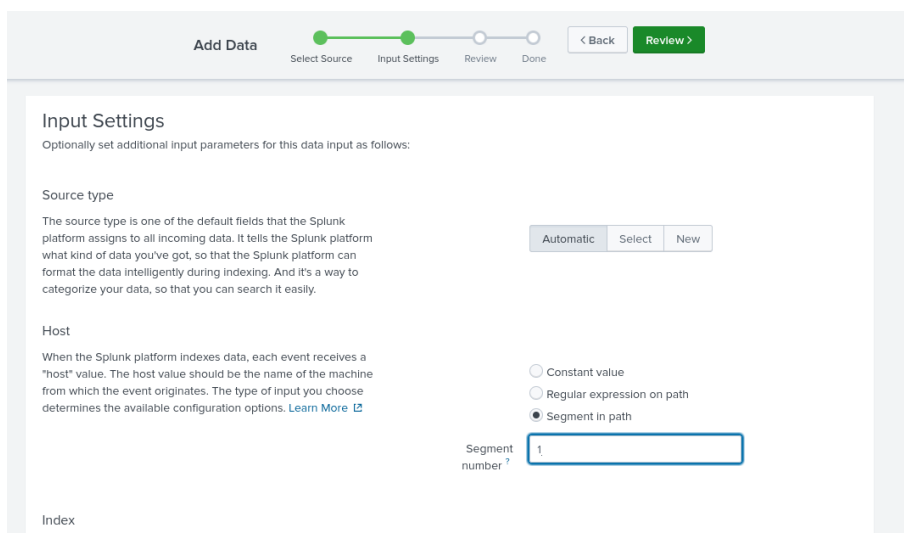


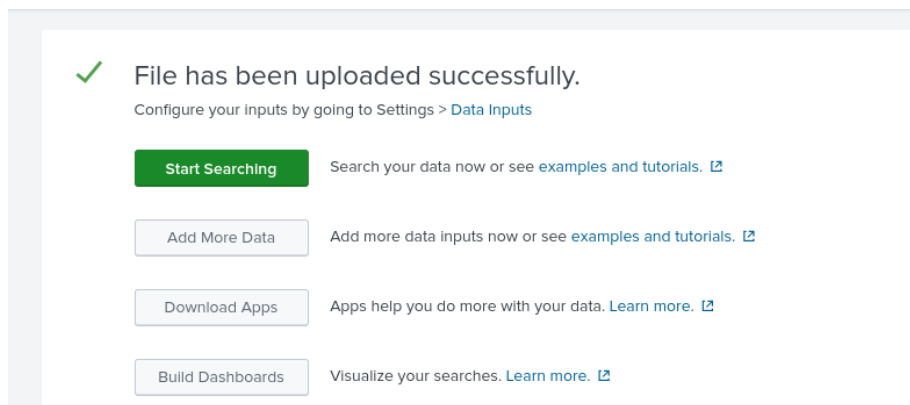
2. Accesso alla funzione Add Data

Accesso a Splunk Web tramite l'URL (<http://kali:8000>), inseriamo le credenziali create in precedenza dal terminale (nome utente admin e la password scelta) Dal menu "Settings", selezionare "Add Data".



"Upload" - "Select file (tutorialdata.zip)" - "Automatic" - "segment in path 1" - "Review" - "Next"





4. Analisi Dettagliata delle 5 Query SPL Eseguite

Per ciascuna query SPL, si fornisce l'obiettivo, il codice, la spiegazione riga per riga e lo screenshot dei risultati ottenuti

4.1 Query 1: Estrazione Tentativi di Accesso Falliti

Obiettivo della Query

Identificare i tentativi di accesso SSH falliti, estraendo utente, IP sorgente e porta utilizzata, per analizzare possibili attacchi brute-force o anomalie di autenticazione.

Codice utilizzato

```
source="tutorialdata.zip:*" "Failed password"  
| rex "Failed password for (?<user>\S+) from (?<src_ip>\S+) port (?<port>\d+)"  
| table _time src_ip user port
```

Spiegazione del codice

1. `source="tutorialdata.zip:*" "Failed password"`
eleziona tutti gli eventi provenienti dal file tutorialdata.zip che contengono la stringa "Failed password".
Questo filtro individua i log di autenticazione SSH con password errata.
2. `| rex "Failed password for (?<user>\S+) from (?<src_ip>\S+) port (?<port>\d+)"`
Utilizzo il comando rex per estrarre, tramite espressione regolare, tre campi: user (nome utente tentato), rc_ip (indirizzo IP sorgente), port (porta di connessione). La regex cerca la sequenza "Failed password for from <src_ip> port".

3. | table _time src_ip user port. Visualizza i risultati in una tabella con le colonne: _time (timestamp dell'evento), src_ip (IP sorgente), user (utente tentato), port (porta utilizzata).

The screenshot shows the Splunk Search interface. The search query is: `source=tutorialdata.zip:* "Failed password"`
`| rex "Failed password for (?<user>S+) from (?<src_ip>S+) port (?<port>S+)"`
`| table _time src_ip user port`

The results are displayed in a table view with the following columns: `_time`, `src_ip`, `user`, and `port`. The table shows four events, all with a timestamp of 1/3/26 9:37:40.000 AM. The events are:

_time	src_ip	user	port
1/3/26 9:37:40.000 AM	194.8.74.23	appserver	3351
1/3/26 9:37:40.000 AM	194.8.74.23	root	3768
1/3/26 9:37:40.000 AM	194.8.74.23	testuser	3626
1/3/26 9:37:40.000 AM	194.8.74.23	apache	4604

The screenshot shows the Splunk Search interface. The search query is: `source=tutorialdata.zip:* "Failed password" rex "(?<user>S+) from (?<src_ip>S+) port (?<port>S+)"`

The results are displayed in a table view with the following columns: `_time`, `src_ip`, `user`, and `port`. The table shows four events, all with a timestamp of 2026-01-03 09:37:40. The events are:

_time	src_ip	user	port
2026-01-03 09:37:40	170.192.178.10	root	4716
2026-01-03 09:37:40	170.192.178.10	root	2416
2026-01-03 09:37:40	207.36.232.245	grumpy	4401
2026-01-03 09:37:40	207.36.232.245	bin	3274

Analisi Approfondita

Questa query consente di monitorare in modo puntuale i tentativi di accesso non autorizzati, identificando pattern di attacco (es. brute-force da IP specifici, targeting di utenti privilegiati). L'estrazione dei campi tramite rex è fondamentale per correlare gli eventi e generare alert mirati.

4.2 Query 2: Accessi Riusciti per Utente Specifico

Obiettivo della Query

Individuare tutti gli accessi SSH riusciti (“Accepted password”) per l’utente “djohnson”, analizzando IP sorgente e timestamp per verificare eventuali compromissioni o attività sospette.

Codice utilizzato

```
source="tutorialdata.zip:*" "Accepted password"
| rex "Accepted password for (?<user>\S+) from (?<src_ip>\S+)"
| search user="djohnson" | table _time user src_ip
```

Spiegazione del codice

1. `source="tutorialdata.zip:*" "Accepted password"`
Filtra gli eventi che contengono la stringa “Accepted password”, cioè accessi SSH riusciti.
2. `| rex "Accepted password for (?<user>\S+) from (?<src_ip>\S+)"`
Estrae tramite regex: user (nome utente autenticato), src_ip (IP sorgente)
3. `| search user="djohnson"`
Filtra ulteriormente i risultati per includere solo quelli relativi all’utente “djohnson”.
4. `| table _time user src_ip`
Visualizza i risultati in tabella con timestamp, utente e IP sorgente.

[illegible]

Analisi Approfondita

Questa query è utile per verificare se l'utente "djohnson" ha subito accessi da IP insoliti o in orari anomali, potenzialmente indicativi di compromissione. L'estrazione dei campi con rex permette di correlare accessi riusciti con tentativi falliti, facilitando l'investigazione forense.

4.3 Query 3: Tentativi Falliti da IP Specifico

Obiettivo della Query

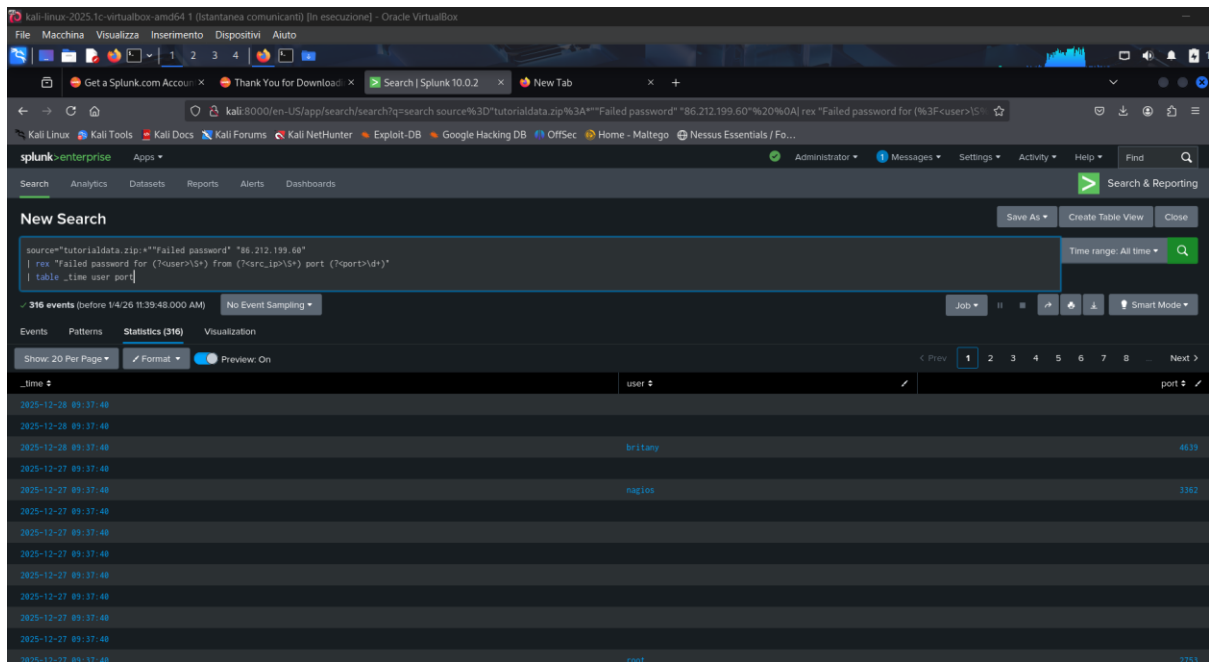
Analizzare i tentativi di accesso SSH falliti provenienti da un IP specifico ("86.212.199.60"), estraendo utente e porta per identificare attacchi mirati o attività sospette da quell'indirizzo.

Codice utilizzato

```
source="tutorialdata.zip:*" "Failed password" "86.212.199.60"  
| rex "Failed password for (?<user>\S+) from (?<src_ip>\S+) port (?<port>\d+)"  
| table _time user port
```

Spiegazione del codice

1. `source="tutorialdata.zip:*" "Failed password" "86.212.199.60"`
Filtra gli eventi che contengono sia "Failed password" che l'IP "86.212.199.60".
2. `| rex "Failed password for (?<user>\S+) from (?<src_ip>\S+) port (?<port>\d+)"`
Estrae i campi `user`, `src_ip` e `port` come nella Query 1.
3. `| table _time user port`
Visualizza i risultati in tabella con timestamp, utente e porta.



Analisi Approfondita

Questa query consente di monitorare attacchi provenienti da un singolo IP, utile per identificare botnet, scanner automatici o attaccanti persistenti. L'analisi delle porte tentate può rivelare pattern di port scanning o tentativi di bypass di policy di sicurezza.

4.4 Query 4: Statistiche Tentativi Falliti per IP

Obiettivo della Query

Calcolare il numero di tentativi di accesso SSH falliti per ciascun IP sorgente, evidenziando quelli che hanno effettuato più di 5 tentativi, potenzialmente indicativi di attacchi brute-force.

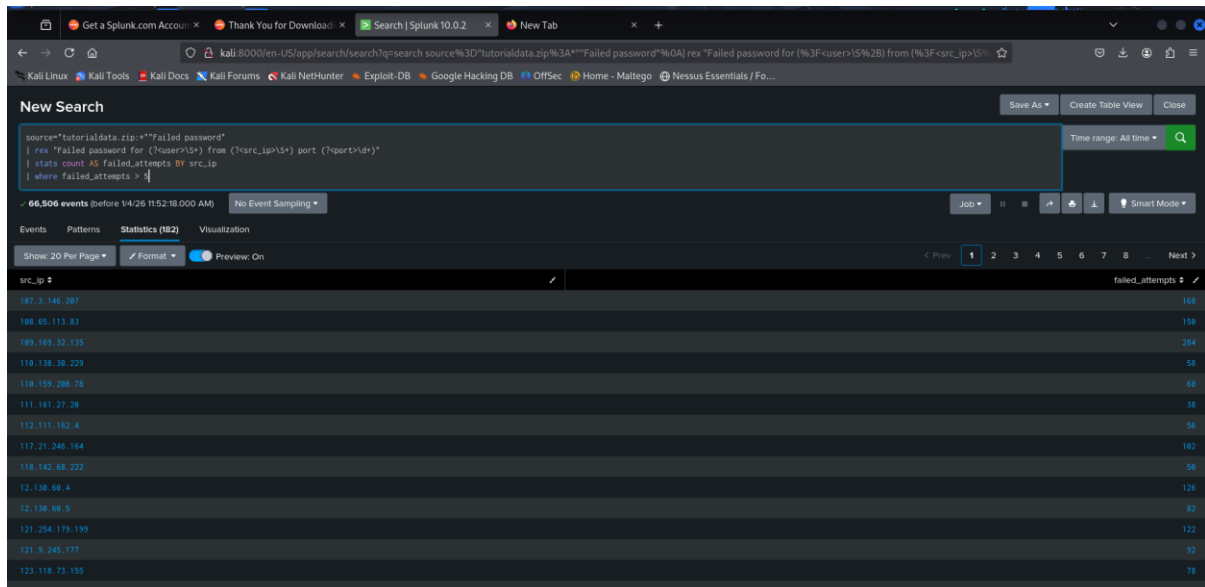
Codice utilizzato

```
source="tutorialdata.zip:*" "Failed password"
| rex "Failed password for (?<user>\S+) from (?<src_ip>\S+) port (?<port>\d+)"
| stats count AS failed_attempts BY src_ip | where failed_attempts > 5
```

Spiegazione del codice

1. `source="tutorialdata.zip:*" "Failed password"`
Filtra gli eventi di accesso fallito.
2. `| rex "Failed password for (?<user>\S+) from (?<src_ip>\S+) port (?<port>\d+)"`
Estrae i campi necessari.

3. | stats count AS failed_attempts BY src_ip
Conta il numero di tentativi falliti per ciascun IP sorgente (src_ip).
4. | where failed_attempts > 5
Visualizza solo gli IP che hanno effettuato più di 5 tentativi falliti.



The screenshot shows a Splunk search interface with the following query in the search bar:

```
source=tutorialdata.zip:*"Failed password"
| rex "failed password for (?<user>[^\s]+) from (?<src_ip>[^\s]+) port (?<port>[^\s]+)"
| stats count AS failed_attempts BY src_ip
| where failed_attempts > 5
```

The search results show 66,506 events. The table below displays the first 15 rows of the results, sorted by failed_attempts in descending order.

src_ip	failed_attempts
187.3.146.287	168
188.65.113.83	158
189.169.32.135	294
110.138.38.229	58
119.155.288.78	65
111.161.27.28	38
112.111.162.4	56
117.21.246.164	102
118.142.68.222	58
12.138.68.4	126
12.138.68.5	82
121.254.179.199	122
121.8.245.177	92
123.118.73.155	78

Analisi Approfondita

Questa query è fondamentale per la rilevazione di attacchi brute-force e password spraying. Gli IP con numerosi tentativi falliti sono spesso indicatori di attività malevola e dovrebbero essere oggetto di alert automatici e misure di mitigazione (es. blocco IP, attivazione MFA).

4.5 Query 5: Ricerca Errori HTTP status=500

Obiettivo della Query

Identificare gli eventi HTTP che hanno restituito lo status code 500 (Internal Server Error), estraendo timestamp, IP client, URI e codice di stato, per analizzare problemi applicativi o potenziali exploit.

Codice utilizzato

```
source="tutorialdata.zip:*" status=500
| table _time clientip uri status
```

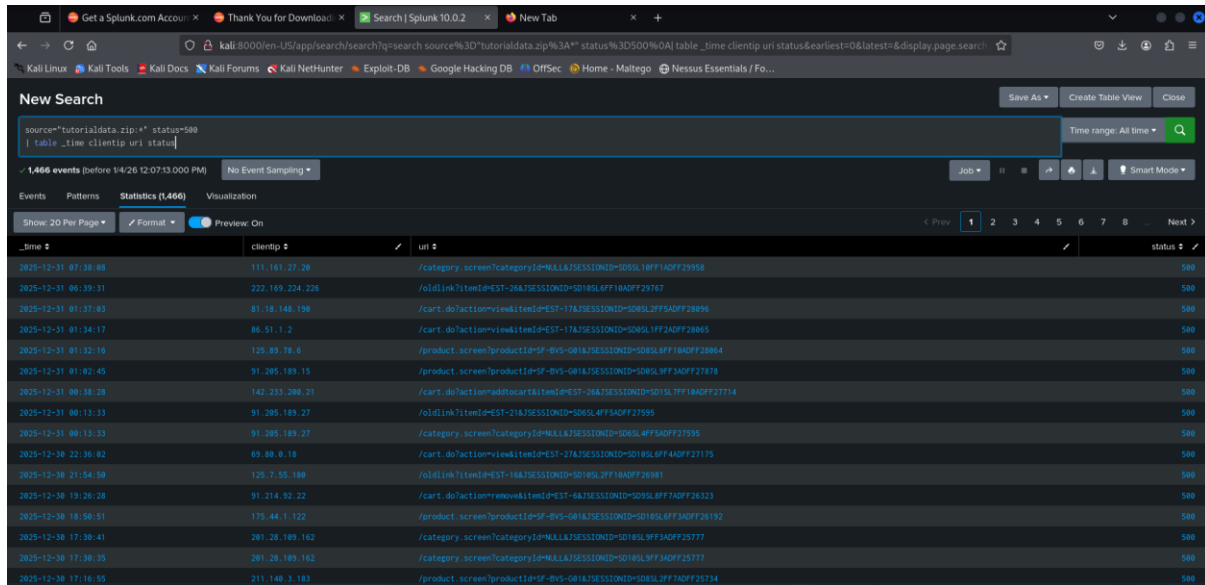
Spiegazione del codice

1. `source="tutorialdata.zip:*" status=500`

Filtra gli eventi HTTP che hanno il campo status uguale a 500, cioè errori server.

2. `| table _time clientip uri status`

Visualizza i risultati in tabella con timestamp, IP client, URI richiesto e codice di stato.



The screenshot shows the Splunk search interface with the query `source="tutorialdata.zip:*" status=500 | table _time clientip uri status`. The results are displayed in a table with columns: `_time`, `clientip`, `uri`, and `status`. The table contains 1466 events, all with a status of 500. The URIs include paths like `/category.screen`, `/oldlink`, `/cart.doAction`, and `/product.screen`.

_time	clientip	uri	status
2025-12-31 07:38:49	111.161.27.29	/category.screen/categoryId=MALL&SESSIONID=505010FF1ADFF2958	500
2025-12-31 06:39:31	222.169.224.205	/oldlink?itemId=EST-26A70ESSIONID=5018516FF1ADFF29767	500
2025-12-31 01:37:43	81.18.142.159	/cart.doAction?itemId=EST-17A70ESSIONID=505010FF1ADFF2958	500
2025-12-31 01:34:17	86.51.1.2	/cart.doAction?itemId=EST-17A70ESSIONID=505010FF1ADFF2958	500
2025-12-31 01:32:16	125.89.79.6	/product.screen/productId=SF-DVS-G81A70ESSIONID=505010FF1ADFF2958	500
2025-12-31 01:02:45	91.285.189.15	/product.screen/productId=SF-DVS-G81A70ESSIONID=505010FF1ADFF2958	500
2025-12-31 00:38:28	142.233.280.21	/cart.doAction?itemId=EST-26A70ESSIONID=5018516FF1ADFF29767	500
2025-12-31 00:13:33	91.285.189.27	/oldlink?itemId=EST-21A70ESSIONID=505010FF1ADFF2958	500
2025-12-31 00:13:33	91.285.189.27	/category.screen/categoryId=MALL&SESSIONID=505010FF1ADFF2958	500
2025-12-30 22:36:02	65.48.0.18	/cart.doAction?itemId=EST-27A70ESSIONID=5018516FF1ADFF29767	500
2025-12-30 21:54:59	125.7.55.188	/oldlink?itemId=EST-16A70ESSIONID=5018516FF1ADFF29767	500
2025-12-30 19:26:28	91.214.92.22	/cart.doAction?itemId=EST-46A70ESSIONID=505010FF1ADFF2958	500
2025-12-30 18:56:31	175.44.1.122	/product.screen/productId=SF-DVS-G81A70ESSIONID=505010FF1ADFF2958	500
2025-12-30 17:38:41	201.28.189.162	/category.screen/categoryId=MALL&SESSIONID=5018516FF1ADFF29767	500
2025-12-30 17:38:35	201.28.189.162	/category.screen/categoryId=MALL&SESSIONID=5018516FF1ADFF29767	500
2025-12-30 17:16:55	211.148.1.183	/product.screen/productId=SF-DVS-G81A70ESSIONID=505010FF1ADFF2958	500

Analisi Approfondita

La ricerca tramite `status=500` è più efficiente e precisa rispetto alla ricerca della stringa “Internal Server Error”, in quanto si basa su un campo strutturato estratto durante l’indicizzazione. Ho utilizzato 500 invece della dicitura Internal Server Error perché nei log web (ad esempio Apache o Nginx) gli errori vengono registrati con il codice di stato HTTP e non con la frase testuale. Il codice 500 è lo standard definito dal protocollo HTTP per indicare un errore generico lato server. È un valore numerico univoco, sempre presente nei log e indipendente dalla lingua o dalla formattazione del messaggio. La dicitura Internal Server Error può variare o non comparire affatto, mentre il codice garantisce un filtro preciso e affidabile.

5. Analisi dei Risultati Ottenuti dalle Query

L’esecuzione delle cinque query SPL sul dataset `tutorialdata.zip` ha permesso di evidenziare diversi aspetti fondamentali per la sicurezza e la gestione operativa:

1. **Monitoraggio degli accessi SSH**

Le Query 1, 3 e 4 hanno evidenziato la presenza di tentativi di accesso falliti, con pattern riconducibili a possibili attacchi brute-force o password spraying.

L'estrazione dei campi tramite rex ha facilitato la correlazione tra IP sorgente, utente e porta, permettendo di identificare attaccanti persistenti e target privilegiati.

2. **Verifica degli accessi riusciti**

La Query 2 ha permesso di monitorare gli accessi riusciti per un utente specifico, utile per individuare compromissioni o attività anomale. La correlazione tra accessi riusciti e tentativi falliti è fondamentale per l'investigazione forense.

3. **Analisi degli errori applicativi**

La Query 5 ha evidenziato la presenza di errori HTTP 500, indicativi di problemi server o potenziali exploit. La ricerca tramite campo strutturato ha garantito precisione e rapidità nell'identificazione degli eventi critici.

4. **Efficienza delle query SPL**

L'utilizzo di SPL e delle espressioni regolari ha dimostrato la flessibilità e la potenza di Splunk nell'estrazione di informazioni da dati non strutturati. La capacità di aggregare, filtrare e visualizzare i risultati in tempo reale è un vantaggio competitivo rispetto a soluzioni tradizionali.

5. **Automazione e alerting**

Le query possono essere facilmente trasformate in alert automatici, dashboard interattive e workflow di risposta, migliorando la proattività e la resilienza del SOC.

Limiti e Considerazioni

- La qualità dei risultati dipende dalla corretta configurazione dei campi e dalla precisione delle regex.
- In ambienti produttivi, è fondamentale implementare policy di retention, backup e auditing per garantire la compliance e la sicurezza dei dati.
- La gestione degli accessi e delle autorizzazioni deve essere rigorosa, applicando best practice di hardening e controllo degli utenti.

6. Conclusioni

Il progetto svolto con Splunk e il dataset tutorialdata.zip ha dimostrato l'efficacia della piattaforma nell'analisi dei log, nella rilevazione delle minacce e nel troubleshooting operativo. L'utilizzo di query SPL avanzate, l'estrazione di campi tramite espressioni

regolari e la visualizzazione dei risultati in dashboard interattive consentono di ottenere una visibilità completa e centralizzata sull'ecosistema IT.

Splunk si conferma uno strumento imprescindibile per i team di sicurezza, amministratori di sistema e analisti, grazie alla sua scalabilità, flessibilità e capacità di automazione. Tuttavia, è fondamentale adottare best practice di sicurezza, gestione dei dati e formazione continua per massimizzare i benefici e minimizzare i rischi.

In un contesto di minacce in continua evoluzione, Splunk rappresenta una piattaforma strategica per la protezione, la compliance e l'ottimizzazione delle infrastrutture digitali.